

CISSP Printable Practice Exam 09 - Domain 1 - Security and Risk Management

Practice Exam 02 - Domain 1

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP2-001)

Scenario: An independent security consultant finds that a client's control environment does not meet the criteria stated in an assessment agreement. The client offers additional work if the consultant removes the adverse findings and issues a favorable conclusion.

What is the consultant's BEST response?

- A. Issue the favorable conclusion but retain the adverse findings in private notes
- B. Refuse to misrepresent the results, report them accurately, and follow the engagement's escalation terms
- C. End the assessment immediately and disclose all client records publicly
- D. Let the client rewrite the conclusion because the client owns the final report

Question 2 (CISSP2-002)

Scenario: A municipal payment system remains continuously accessible, and no account data is exposed. However, an unauthorized user changes payment amounts before they are submitted for settlement.

Which security objective is MOST directly compromised?

- A. Availability
- B. Confidentiality
- C. Non-repudiation
- D. Integrity

Question 3 (CISSP2-003)

Scenario: A diversified company has a security steering committee, but meetings produce recommendations that business units routinely ignore. The committee has no approved charter, decision rights, or escalation path.

Which improvement should executive leadership make FIRST?

- A. Approve a charter defining membership, authority, accountability, reporting, and escalation
- B. Ask the security operations team to enforce every recommendation independently
- C. Replace business representatives with only technical specialists
- D. Measure the committee solely by the number of meetings it conducts

Question 4 (CISSP2-004)

An enterprise adopts a recognized security control framework as the common basis for its program. Which 2 outcomes should this MOST directly support? Select 2 of the 5 options below.

- A. A structured method for selecting and organizing controls according to risk
- B. Automatic elimination of all residual risk after implementation
- C. A common vocabulary for communicating and assessing control expectations
- D. Replacement of business ownership for security risk
- E. Exemption from legal and contractual obligations

Question 5 (CISSP2-005)

Scenario: A corporation will sell one of its divisions. For six months after closing, the seller will continue operating several shared services while data and personnel are

separated between the two organizations.

What should the security leaders establish as the HIGHEST governance priority before closing?

- A. A plan to give the buyer unrestricted access to all shared systems during transition
- B. A requirement to erase every record associated with the division before legal review
- C. A separation plan defining data ownership, access boundaries, retained obligations, monitoring, and exit milestones
- D. An agreement that the seller will accept every risk created after the sale

Question 6 (CISSP2-006)

Scenario: A nonprofit completed a documented risk assessment and identified excessive exposure involving donor records. Management then funded proportionate safeguards, assigned control owners, and verifies that the safeguards continue to operate.

Which concept is MOST clearly demonstrated by management's actions after the assessment?

- A. Risk avoidance through discontinuing the activity
- B. Due care through reasonable protection and continued control operation
- C. Risk transfer through assigning internal control owners
- D. Non-repudiation through documenting the original assessment

Question 7 (CISSP2-007)

Scenario: A business sues a former service provider for monetary damages, alleging that negligent handling of confidential data breached the parties' agreement. No government prosecutor is seeking punishment.

How is this matter BEST classified?

- A. A criminal prosecution requiring proof beyond a reasonable doubt
- B. An administrative licensing action decided only by a regulator
- C. An industry audit with no possible legal consequences
- D. A civil action generally decided under a preponderance-of-the-evidence standard

Question 8 (CISSP2-008)

Scenario: A laboratory has an approved policy requiring prompt revocation of access when personnel leave. Administrators need an authorized, repeatable sequence showing exactly how to receive notice, disable accounts, recover credentials, document completion, and escalate exceptions.

Which document should contain this sequence?

- A. Procedure
- B. Guideline
- C. Policy
- D. Risk appetite statement

Question 9 (CISSP2-009)

Scenario: Corporate counsel informs a communications company that litigation is reasonably anticipated. Potentially relevant messages are scheduled for routine deletion under the normal retention schedule.

What should the investigation and records teams do NEXT?

- A. Continue routine deletion until a court issues a final judgment

- B. Preserve only records that clearly favor the organization
- C. Issue and document a legal hold covering relevant custodians and data sources
- D. Immediately provide all organizational records to the opposing party

Question 10 (CISSP2-010)

A company wants to protect original training videos and a novel, useful technical invention for which it is prepared to disclose the design in an application. Which 2 forms of intellectual property protection are MOST directly applicable? Select 2 of the 5 options below.

- A. Trademark for the functional invention
- B. Copyright for the original training videos
- C. Trade secret protection after publicly disclosing every implementation detail
- D. Patent protection for the qualifying technical invention
- E. A nondisclosure agreement as automatic ownership registration for both assets

Question 11 (CISSP2-011)

Scenario: An aerospace supplier plans to let engineers in another country remotely access controlled technical documentation and security-related source material. The project manager considers remote access different from an export because no physical media will cross a border.

What should the security and legal teams determine BEFORE granting access?

- A. Whether remote access makes the information public and therefore unrestricted
- B. Whether export-control classification, destination, recipient, licensing, or authorization requirements apply
- C. Whether the foreign engineers agree to use the same operating system
- D. Whether a confidentiality label alone eliminates government restrictions

Question 12 (CISSP2-012)

Scenario: A regulator requests records related to a suspected compliance failure. Several employees have access to the source repository, and the organization must be able to show that collected records were not altered after acquisition.

Which practice provides the STRONGEST support for evidence integrity?

- A. Allow investigators to edit originals so annotations remain with each record
- B. Rely on employee recollection to establish which files were collected
- C. Print selected records and discard the original electronic versions
- D. Use documented collection, cryptographic hashes, controlled storage, and a complete chain of custody

Question 13 (CISSP2-013)

In an illustrative analysis, an information asset is valued at \$600,000 and a single event is expected to cause a 30 percent loss. What is the single loss expectancy?

- A. \$18,000
- B. \$60,000
- C. \$180,000
- D. \$2,000,000

Question 14 (CISSP2-014)

Scenario: A publishing company purchases cyber insurance covering defined response expenses. An executive then proposes removing the insured scenarios from the risk register because the insurer will pay covered claims.

How should the risk manager respond?

- A. Keep the risks under management because insurance transfers specified financial impact but leaves exclusions, residual exposure, and accountability
- B. Remove the risks because an insurance policy eliminates their likelihood
- C. Transfer ownership of the affected business processes to the insurer
- D. Stop maintaining preventive controls for every insured event

Question 15 (CISSP2-015)

Scenario: A cultural institution must prioritize emerging risks, but it lacks credible frequency and loss data for several scenarios. Subject-matter experts can compare likelihood and impact using defined criteria.

Which approach is MOST appropriate?

- A. Invent precise monetary values so every risk appears quantitative
- B. Use documented qualitative scales and calibration criteria to rank likelihood and impact
- C. Treat every scenario as equally severe until a loss occurs
- D. Exclude risks that cannot be assigned an exact annualized loss expectancy

Question 16 (CISSP2-016)

A threat-modeling team identifies one scenario in which a user can deny submitting a request because actions are not reliably recorded, and another in which excessive requests make a service unavailable. Which 2 STRIDE categories apply? Select 2 of the 5 options below.

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Information disclosure
- E. Denial of service

Question 17 (CISSP2-017)

Scenario: A payroll provider meets the customer's initial security requirements but plans to move critical processing to a new subcontractor. The existing agreement does not require disclosure or approval of material subcontractor changes.

What is the BEST governance response?

- A. Treat the subcontractor as irrelevant because the direct provider passed its original review
- B. Allow the change if the direct provider promises verbally to remain responsible
- C. Prohibit every subcontractor regardless of business need or assessed risk
- D. Assess the new dependency and establish contractual notice, flow-down controls, monitoring, and accountability

Question 18 (CISSP2-018)

Scenario: A design company depends on an external platform for a time-critical workflow. The draft service-level agreement says only that the provider will use reasonable security and make best efforts to restore service.

Which revision would MOST improve the company's ability to manage the risk?

- A. Replace all security language with a general statement of trust
- B. Let the provider define performance after an outage occurs
- C. Add measurable availability, recovery, incident-notification, reporting, escalation, and remedy provisions
- D. State that outsourcing makes the provider the sole owner of business risk

Question 19 (CISSP2-019)

Scenario: A food distributor lists order fulfillment as its most time-sensitive process. During a business impact analysis workshop, the process owner identifies warehouse staffing, identity services, carrier interfaces, and supplier data as prerequisites.

How should the continuity planner use this information?

- A. Incorporate the dependencies into recovery priorities, sequencing, and strategy requirements
- B. Set recovery priorities using only the replacement cost of the ordering application
- C. Exclude third-party dependencies because the organization cannot operate them directly
- D. Assign every dependency the same recovery objective without impact analysis

Question 20 (CISSP2-020)

Scenario: A hospitality group is revising pre-employment screening across several jurisdictions. Some roles handle cash or sensitive records, while others have limited access. Local rules differ regarding notice, consent, and permissible checks.

Which approach is MOST appropriate?

- A. Perform the most intrusive available investigation for every applicant
- B. Skip screening because jurisdictional differences make consistent governance impossible
- C. Let each hiring manager request any personal information considered interesting
- D. Define role-based screening that is relevant, consistently applied, documented, and compliant with applicable law

Question 21 (CISSP2-021)

Scenario: A new financial systems administrator starts next week. The manager requests broad access on the first day so the employee can explore the environment while responsibilities are finalized.

What should the security team require?

- A. Broad temporary access because short-lived privileges do not create material risk
- B. Approved role-based access, required agreements and policy acknowledgment, and job-specific security training
- C. Use of a predecessor's account until the new role is fully documented
- D. Access approval by the new employee without business-owner involvement

Question 22 (CISSP2-022)

Scenario: A regional transit authority has updated its continuity plan but has not exercised it. Leaders want to validate decision-making without disrupting live service and also verify that departmental recovery procedures can be performed in sequence.

Which 2 exercise activities BEST meet these goals? Select 2 of the 5 options below.

- A. A facilitated tabletop exercise for leaders using an evolving disruption scenario
- B. A structured walkthrough in which teams review responsibilities and procedural steps
- C. An unannounced shutdown of all production services as the first exercise
- D. A document-signing session with no scenario discussion or procedural review
- E. A permanent waiver of future testing after management approves the plan

Question 23 (CISSP2-023)

Which statement BEST describes the relationship between business continuity and disaster recovery?

- A. Disaster recovery governs every business workaround, while business continuity covers only data restoration
- B. The terms are interchangeable because both address only technology outages
- C. Business continuity sustains critical operations, while disaster recovery focuses more specifically on restoring technology and related capabilities
- D. Business continuity begins only after all disaster recovery work is complete

Question 24 (CISSP2-024)

Scenario: A construction company sees a rise in fraudulent payment-change requests directed at project coordinators. Its existing awareness program focuses mainly on physical office security and is reviewed only every three years.

What is the BEST program response?

- A. Update the program using current risk information, deliver targeted practice to exposed roles, and measure reporting and verification behavior
- B. Wait for the scheduled three-year review so awareness remains consistent
- C. Send the same physical-security material more frequently to all personnel
- D. Transfer responsibility for payment verification entirely to the awareness team

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP2-001) - Correct: B

Honest, competent, and responsible professional service requires the consultant to report supported conclusions and resist pressure to misrepresent evidence. Contractual escalation provisions provide an appropriate path for resolving the dispute. Private notes do not cure a false report, public disclosure could violate confidentiality, and client ownership does not justify an inaccurate professional conclusion.

Question 2 (CISSP2-002) - Correct: D

Integrity concerns the accuracy, completeness, and authorized modification of information. Altering payment amounts directly violates that objective. The system remains available, no disclosure indicates a confidentiality loss, and non-repudiation concerns evidence that a party performed an action rather than the correctness of the payment data itself.

Question 3 (CISSP2-003) - Correct: A

A formally approved charter establishes the committee's mandate, decision rights, accountability, representation, and escalation route. Operational enforcement without delegated authority bypasses governance. Removing business representatives weakens alignment and risk ownership, while meeting counts measure activity rather than the quality or effect of decisions.

Question 4 (CISSP2-004) - Correct: A, C

A recognized framework provides an organized basis for choosing, describing, and assessing controls and gives stakeholders a consistent vocabulary. It does not eliminate residual risk, transfer business accountability, or supersede laws and contracts. The framework supports governance decisions; it does not make those decisions or obligations disappear.

Question 5 (CISSP2-005) - Correct: C

A divestiture needs an approved separation plan that assigns ownership, limits access, preserves required records and obligations, monitors transition risk, and defines how shared services will end. Unrestricted access creates exposure, blanket deletion may violate retention duties, and unlimited risk acceptance fails to allocate responsibilities realistically.

Question 6 (CISSP2-006) - Correct: B

Due care is demonstrated by taking and sustaining reasonable protective measures in response to known risk. The earlier assessment reflects due diligence, while the funded safeguards and assigned operation show care in practice. The activity was not discontinued, internal ownership does not transfer the risk, and assessment documentation alone does not provide non-repudiation.

Question 7 (CISSP2-007) - Correct: D

A private claim seeking damages for negligence and breach is a civil action, and civil cases generally use the preponderance-of-the-evidence standard. It is not a criminal prosecution because the government is not seeking penal sanctions. The facts also do not describe a regulator's licensing action or merely an industry audit.

Question 8 (CISSP2-008) - Correct: A

A procedure provides the detailed, repeatable steps used to carry out a requirement. The policy states management's direction, while a guideline supplies recommended rather than mandatory advice. A risk appetite statement defines the broad amount and type of risk the organization is willing to pursue or retain, not an operational workflow.

Question 9 (CISSP2-009) - Correct: C

Once litigation is reasonably anticipated, relevant information must be preserved through a documented legal hold that identifies custodians, systems, and affected retention processes. Continuing routine deletion risks spoliation, selective preservation undermines integrity, and preservation does not mean indiscriminately disclosing every organizational record.

Question 10 (CISSP2-010) - Correct: B, D

Copyright protects original expressive works such as training videos, while a qualifying novel and useful invention may be protected through the patent process in exchange for disclosure. Trademark identifies the source of goods or services rather than protecting function. Public disclosure is inconsistent with preserving a trade secret, and a nondisclosure agreement does not itself register ownership rights.

Question 11 (CISSP2-011) - Correct: B

Export controls can apply to transfers of controlled technical information or technology through electronic and remote access, not only physical shipment. Classification, destination, recipient, end use, and licensing or authorization must be evaluated. A shared operating system is irrelevant to legal authorization, and neither remote delivery nor a confidentiality label removes applicable restrictions.

Question 12 (CISSP2-012) - Correct: D

Documented acquisition, integrity hashes, controlled preservation, and a complete chain of custody provide defensible evidence that records remained unchanged and handling was accountable. Editing originals compromises integrity, recollection is weak documentation, and discarding native electronic records can remove important metadata and undermine the investigation.

Question 13 (CISSP2-013) - Correct: C

Single loss expectancy equals asset value multiplied by exposure factor: $\$600,000 \times 0.30 = \$180,000$. The annualized rate of occurrence is not needed for this calculation; it would be used later with SLE to estimate annualized loss expectancy. The other values result from misplaced decimals or division rather than multiplication.

Question 14 (CISSP2-014) - Correct: A

Insurance transfers defined financial consequences subject to limits, exclusions, and conditions; it does not remove the event's likelihood, operational harm, reputational effects, or the organization's accountability. The business still owns its processes and must maintain appropriate controls and monitoring. Therefore, the risks remain in the risk-management process.

Question 15 (CISSP2-015) - Correct: B

Defined qualitative scales allow consistent expert judgment when reliable numerical inputs are unavailable. Calibration criteria reduce ambiguity and help prioritize treatment. Fabricated precision makes results misleading, equal rankings prevent useful prioritization, and excluding hard-to-quantify risk can hide significant exposure.

Question 16 (CISSP2-016) - Correct: C, E

The inability to hold a user accountable for a submitted request is a repudiation threat. Making a service unavailable through excessive requests is denial of service. Spoofing concerns impersonation, tampering concerns unauthorized modification, and information disclosure concerns unauthorized exposure; none describes the two stated scenarios as directly.

Question 17 (CISSP2-017) - Correct: D

Material subcontractors can introduce fourth-party exposure, so governance should require visibility, risk assessment, appropriate flow-down requirements, monitoring, and clear accountability. The initial review does not cover a changed dependency, verbal assurances are weak, and a universal ban disregards proportionate, risk-based business decisions.

Question 18 (CISSP2-018) - Correct: C

Measurable service, recovery, notification, reporting, escalation, and remedy terms let the customer monitor performance and respond when obligations are missed. Vague trust or best-effort language is difficult to enforce. Post-event definitions provide no advance assurance, and outsourcing does not eliminate the customer's ownership of business risk.

Question 19 (CISSP2-019) - Correct: A

Critical-process recovery depends on the people, technology, information, facilities, and third parties that enable it. Those dependencies must shape recovery sequence and strategy. Application cost alone does not measure operational impact, external dependencies remain relevant even when not directly controlled, and identical objectives may waste resources or fail business needs.

Question 20 (CISSP2-020) - Correct: D

Screening should be proportionate to the role's risk, based on job-related criteria, consistently governed, and conducted under applicable notice, consent, privacy, and employment requirements. Maximum intrusion can be unlawful and unnecessary, abandoning screening ignores legitimate risk, and ad hoc manager requests create inconsistency and privacy exposure.

Question 21 (CISSP2-021) - Correct: B

Secure onboarding establishes identity, approved least-privilege access, required agreements, policy acknowledgment, and role-specific preparation before sensitive duties begin. Broad exploratory privileges exceed established need, inherited accounts destroy accountability, and employees cannot authorize their own access without accountable ownership and segregation of duties.

Question 22 (CISSP2-022) - Correct: A, B

A tabletop exercise tests leadership decisions and coordination through a low-disruption scenario, while a structured walkthrough validates roles, dependencies, and procedural sequence. A full unannounced shutdown is disproportionate for a first exercise, signatures alone do not test capability, and continuity plans require recurring validation as people, systems, and risks change.

Question 23 (CISSP2-023) - Correct: C

Business continuity is the broader discipline for sustaining critical organizational activities through disruption. Disaster recovery supports that objective by restoring technology, infrastructure, and related services. Treating the terms as identical or reversing their scope overlooks people, facilities, suppliers, communications, and manual workarounds that continuity planning may address.

Question 24 (CISSP2-024) - Correct: A

An effective program responds to current threats and audience-specific exposure, reinforces the expected verification and reporting behaviors, and measures whether those behaviors improve. Waiting preserves a known gap, repeating unrelated content does not address the risk, and the awareness team educates personnel but does not own operational payment

controls.